

ADR-0006 — Comment sécuriser l'application

Status : Accepté

Date : 09/10/2026

Contexte

L'API est exposée sur Internet, n'importe qui peut lui envoyer une requête, et les commandes reçues servent ensuite à entraîner le modèle. Une entrée malveillante peut donc fausser les prédictions futures.

Les commandes, le catalogue PostgreSQL, les fichiers sur Garage et les artefacts du modèle sont sur un VPS partagé avec d'autres projets (ADR-0003).

Options considérées

Option	Avantage	Inconvénient
A. Périmètre seul (pare-feu + HTTPS)	Simple, déjà en place sur le VPS	Une fois l'API atteinte, rien ne limite ce qu'elle reçoit ni ce à quoi elle accède
B. Passerelle managée devant l'API (Cloudflare, API Gateway)	Filtrage, limite de débit et authentification fournis	Service tiers par lequel passent toutes les requêtes, ne protège pas l'accès aux données
C. Défense en profondeur avec les briques du VPS	Chaque couche limite les dégâts si la précédente cède ; aucun service en plus	Plus de réglages à maintenir

Décision

Option C : une protection à chaque étape, avec les outils déjà en place.

Axe	Mesure
Entrées	HTTPS uniquement (Traefik géré par Coolify), validation stricte par les schémas du contrat, champ manquant, en trop ou hors bornes refusé en 422 avant le code métier, clé d'API exigée dans l'en-tête <code>X-API-Key</code> sur les routes <code>/v1/*</code> , refus en 401 sinon, les sondes <code>/health</code> restant ouvertes pour Coolify, limite de débit par IP dans Traefik
Sorties	Réponses limitées aux champs du contrat, erreurs au format <code>Error</code> , sans trace ni détail interne, aucun secret dans les logs
Accès à la donnée	PostgreSQL et Garage joignables seulement par le réseau Docker interne, jamais depuis Internet, administration par Tailscale uniquement, clé Garage <code>ia-cloud</code> limitée au bucket <code>ia-cloud</code> et rôle PostgreSQL limité au catalogue, secrets dans les variables Coolify, jamais dans git, conteneur lancé sans les droits root

Conséquences

Si l'API est compromise, elle n'atteint que ses propres données, pas celles des autres projets du VPS.

Les commandes ne contiennent aucune donnée personnelle directe (ni nom, ni adresse), ce qui limite l'impact d'une fuite.